

Per-entity anomaly detection in security telemetry

John Pierman · github.com/JohnPierman/ethogram

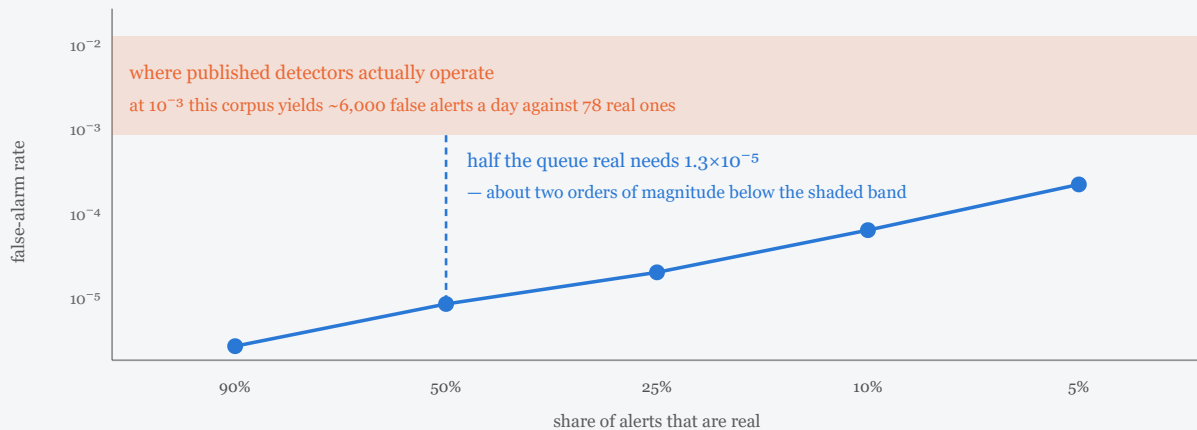
Every number in this paper is read from a recorded run committed under `results/`. Where a claim has no backing run, the section says so and is left empty rather than filled.

1. The problem

An intrusion detector reads authentication logs and decides which events an analyst should look at. The difficulty is arithmetic before it is anything else.

On the public LANL authentication corpus [2] used throughout this paper, days 7 to 13 contain **42,218,530 scored events, of which 549 are labelled red-team activity** — a base rate of 1.30×10^{-5} , or one in 76,901.

false-alarm rate needed for a given share of alerts to be real, at this corpus's base rate



The base rate, not the model, sets the ceiling. Over the scored window this corpus carries 549 labelled events among 42,218,530 — one in 76,901. Inverting the arithmetic for a desired precision gives the false-alarm rate a detector would have to achieve, and it lands two to three orders of magnitude below where published detectors operate. Two consequences follow: "everything suspicious and nothing else" is not attainable here by any known method, and even a perfect detector still yields 87 alerts a day, because 78 genuinely suspicious events happen daily. What an operator can choose is the error rate; the volume follows from it.

At that base rate, precision is governed by the false-alarm rate and almost nothing else. For a detector that misses nothing, the share of alerts that are real is

$$P(\text{intrusion} \mid \text{alarm}) = p / (p + (1 - p) \cdot \alpha)$$

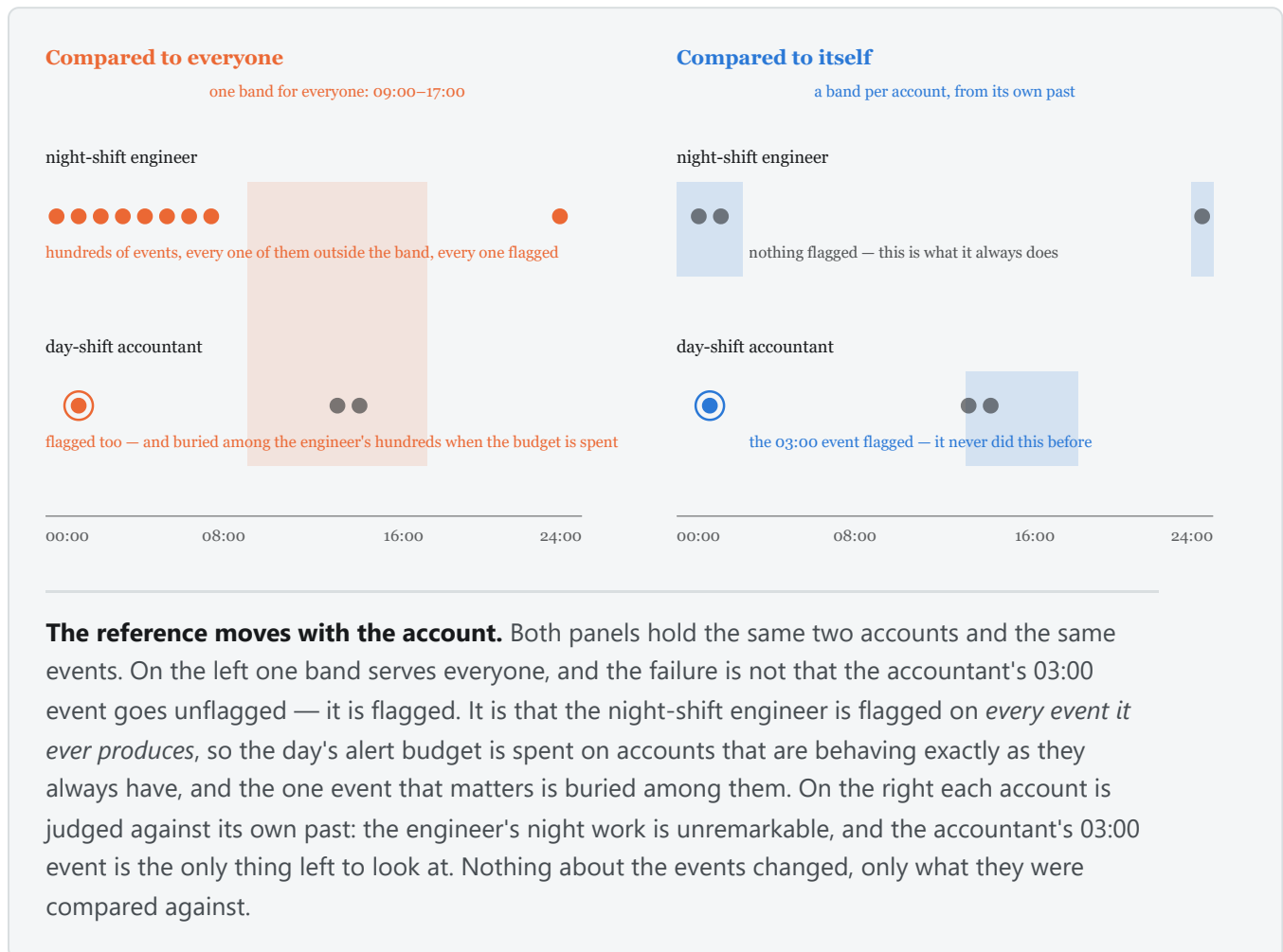
so a queue that is half real requires $\alpha \approx 1.3 \times 10^{-5}$: about 78 false alerts a day against 78 real ones. Axelsson [1] reached the same order of magnitude from a structurally identical scenario, and concluded that suppressing false alarms, rather than recognising intrusions, is the binding constraint. Published detectors typically operate

two to three orders of magnitude above what the arithmetic permits.

1.1 Why the standard formulation cannot get there

The conventional approach reduces each event to a fixed-length numeric vector and fits one model over the pooled cloud: isolation forests [11], local outlier factor [14], one-class SVM [15], PCA reconstruction error, autoencoders. All are instances of the same question — **is this point unusual for the population?**

That question is the wrong one, and the failure is not a matter of tuning.



A night-shift engineer authenticating at 03:00 is unusual for the organisation and entirely ordinary for herself. A population-scope model flags her every night. Worse, it flags her *hundreds of times*, so when a budget is spent she consumes it, and the one account that has genuinely changed behaviour is buried. The corpus bears this out: of the 549 labelled events, **not one is a population-marginal outlier**.

The question worth asking is *is this unusual for **this** account, against its own history*. An account that habitually departs from the population norm is not thereby anomalous. That single commitment is what this work is about, and it is also the axis its results divide along.

1.2 What a usable answer looks like

Three properties follow from the arithmetic, and they are requirements rather than aspirations.

A score must be **comparable**: not "0.87 anomalous" but a p-value under an explicitly stated null, so that two detectors' outputs can be reasoned about together and a threshold means something.

A detector with no inputs must **decline**. Silence and normality are different findings, and a system that reports the second when it means the first is quietly wrong at scale.

A verdict must carry **evidence**: if an analyst cannot reconstruct why an event surfaced, the alert generates work rather than reducing it.

2. The approach and the framework

2.1 The entity-conditioned null

Every detector states a null hypothesis of the same shape:

H₀ — the observed value is drawn from *this entity's own* historical distribution, estimated from its decayed counts.

The framework holds seven such detectors. Each returns a p-value under its stated null, or abstains. Five ask about the entity; two ask about the population, and are kept deliberately so that the per-entity arms can be credited only with what they add beyond what a conventional model already does.

DETECTOR	NULL HYPOTHESIS	SCOPE	DEFAULT
I <code>novelty</code>	the value is drawn from the entity's historical distribution over that field	entity	on
II(a) <code>timing</code>	the event's time of day is drawn from the entity's historical circular density	entity	on
II(b) <code>volume</code>	the count in this window is drawn from the entity's negative binomial	entity	on
III <code>cooccurrence</code>	the pair's co-occurrence weight is drawn from a Poisson degree-corrected block model [9]	population	on
IV <code>marginal</code>	the value is drawn from the population marginal for its field	population	on
V <code>noveltyrate</code>	the count of first-ever values in this window follows the entity's own historical rate	entity	opt-in
— <code>pairing</code>	the pairing is drawn from the entity's own history of pairings	entity	opt-in

2.2 No component knows what a field is

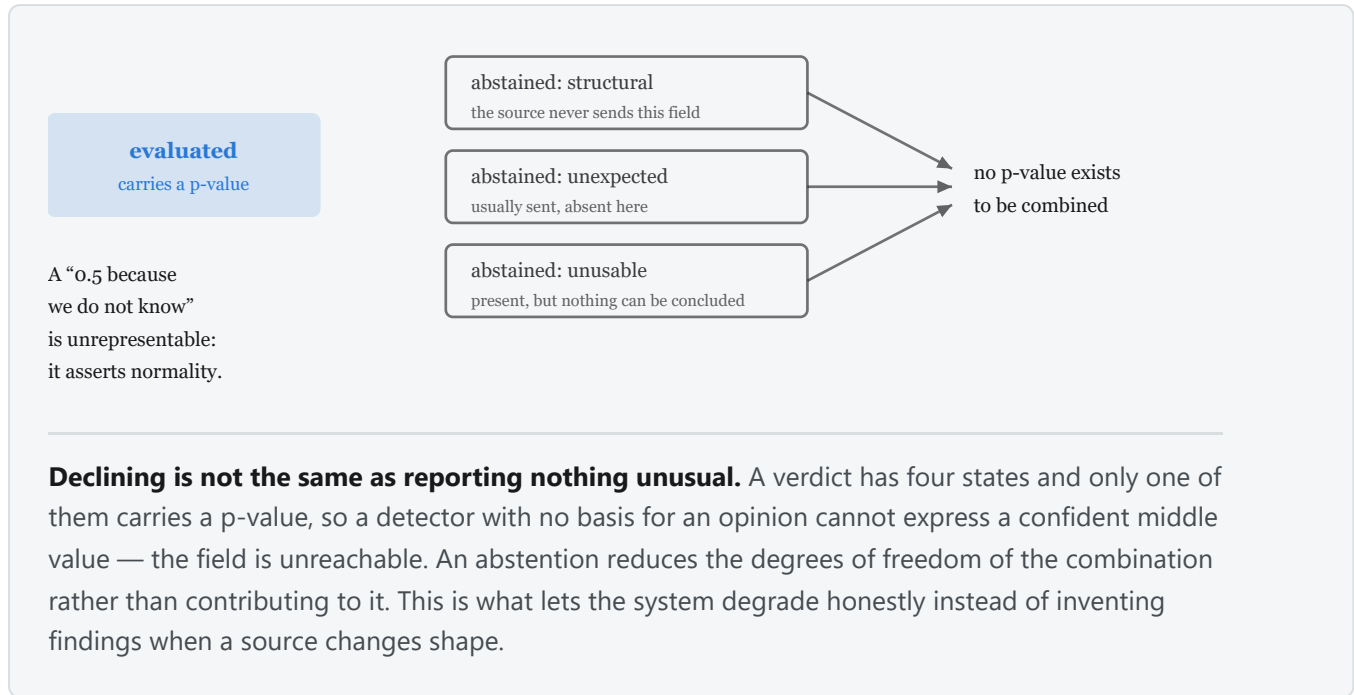
The framework names no field anywhere in its code. Readers emit every value as text; a registry infers each field's *kind* from the values it observes — categorical, boolean, discrete, continuous, identifier — together with the statistics supporting that classification. Detectors iterate the registry; none names a field.

Nothing is cast to a type. A per-batch cast would make a value's reading depend on which rows it arrived with, would merge values a source distinguishes (`007` and `7`, `TRUE` and `true`), and would commit before the evidence is in, since a column that looks integral for forty-nine events can emit a sentinel on the fiftieth. Instead each kind supplies the *representation* its detectors can score: the value's own text where the vocabulary is already bounded, and a fixed-boundary magnitude band where it is not. Where a vocabulary is open rather than bounded, the mass reserved for the unseen follows Good–Turing [8].

The identifier case is load-bearing. A field taking a distinct value on essentially every event is formally maximally novel on every observation; untreated it saturates any novelty detector, grows state without bound, and reduces a co-occurrence graph to singletons. Such fields are detected from their statistics and contribute neither state nor verdicts.

Measured: a second, structurally unrelated source — LANL DNS — was admitted and scored with **zero changes to any extractor**, reading 6,004,253 rows and scoring 5,599,989 events.

2.3 Abstention is a first-class outcome



A verdict carries a four-valued status. **evaluated** carries a p-value; the three abstentions say *why* there is none — the input was absent and the source does not ordinarily produce it, the input was absent and it ordinarily does, or the input was present but not interpretable. A p-value is unreachable unless the status is **evaluated**, so an abstention cannot be silently read as normality.

2.4 Determinism, and evidence

Identical event and state must produce identical output. This requires closing specific leaks — no wall clock and no randomness in the scoring path, and a canonical total ordering before every floating-point reduction — and it is enforced structurally, by an AST-level test rather than by convention.

Measured: one probe event scored inside batches of **37, 38, 87, 537 and 2,037** events yielded the identical combined p-value of $1.2637402747461349 \times 10^{-5}$ in every case. The same event scored 64 times against the same state produced **one digest**. A deliberately defective detector, standardising against its own batch, is required to *fail* the same check, and does — because a check that cannot fail is not evidence.

Measured: **79.2% of 49,581 sampled verdicts** were reconstructable by hand from the evidence card alone, with no query back to the store.

2.5 The requirements

REQUIREMENT	ENFORCED BY
R1 No score may depend on the composition of the batch the event arrived in	Score reads only persisted state; E8 asserts byte-identical scores across batch sizes, with a negative control proving the check can fail
R2 No component may require advance knowledge of a field's type, cardinality or value set	readers emit generic field paths; the registry infers kinds; the estimator reserves mass for the unseen
R3 A detector without inputs must decline rather than assert normality	a p-value is unreachable unless the status is evaluated
R4 Identical event and state must yield identical output, reproducibly	no wall clock and no randomness in the scoring path, enforced by an AST-level test
R5 Every verdict must carry evidence sufficient to reconstruct it by hand	sufficient statistics <i>are</i> the evidence; E7 measures the share that reconstruct
R6 An alerted entity must be more likely than not to be genuinely anomalous. Alert volume is explicitly not bounded	nothing yet — measured, not asserted, and currently unmet

R6 replaced an earlier requirement that an operator-chosen error rate map to a predictable alert volume. That requirement was withdrawn rather than satisfied: it was never met, its enforcement mechanism — false-discovery control [6], in the dependency-tolerant form [7] the detectors' correlation requires — was measured to be vacuous on this corpus, reporting a realised false discovery rate of 1.0 at every nominal level. Holding the requirement made a bounded queue the objective when the binding problem is that the queue's contents are wrong. R6 is the only requirement here that is not a structural property, and that is stated rather than glossed: R1–R5 fail a build, R6 can only be measured against labelled data.

2.6 What an alert is worth

Alert volume is deliberately unbounded. The objective is

$$U = v \cdot TP - c \cdot FP$$

where **v** is what catching one incident is worth and **c** what one wasted investigation costs. Only the ratio is identifiable from counts, so the operator supplies one number. A queue is worth reading exactly when $TP/FP > c/v$, so a target true-to-false ratio is the exchange rate — but utility also says *how many* rows to take, which a ratio cannot.

This matters because maximising TP/FP directly does not work. It is precision under a monotone transform, $P/(1-P)$, so its maximiser is the smallest queue containing a true positive; forbidding $TP = 0$ moves that corner from "alert on nothing" to "alert on one thing" rather than removing it. An objective must contain a term that grows with true positives found.

A budget is therefore a **ceiling, not a quota**: within it, the queue is truncated where marginal alerts stop paying.

3. Results

All figures are at matched alert budgets, expressed per analyst-day.

3.1 What each method detects

Every method this project measures, against every kind of attack it has ground truth for, at **1000 alerts a day**. `lanl-inj-b1000-union-d7-14-002` and `baselines-injected-r7-d7-14` : 856 planted attacks across six types plus the 549 real labelled events, 1,405 in all. Attribution is by victim account, which the taxonomy makes unambiguous -- victims are disjoint from every account the real labels name, so the account alone says which ground truth an event belongs to. A dash is a method no run measured at this budget, which is not the same statement as a zero and is never rendered as one.

METHOD	SPRAY	LATERAL	OFF-HRS	PRIV-ESC	LOW+SLOW	TAKEOVER	REAL	TOTAL	ALERTS
<i>per-entity detector</i>									
novelty	80	15	0	0	0	30	178	303	7000
noveltyrate	117	26	0	4	0	64	173	384	7000
pairing	0	0	0	0	0	12	130	142	7000
timing	0	0	2	0	0	4	6	12	7000
volume	0	0	0	0	0	0	0	0	7000
<i>population detector</i>									
marginal	0	0	0	0	0	120/120	0	120	7000
<i>combination</i>									
composite (Fisher + Brown)	0	4	0	0	0	116	108	228	7000
corrected minimum (Å idÅik)	40	10	0	0	0	30	155	235	7000
union, per-entity arms (equal cost)	2	0	0	0	0	15	101	118	7000
union, per-entity arms (equal depth)	117	26	2	4	0	64	264	477	25917 (Å −3.7)
union, all arms (equal cost)	0	0	0	0	0	120/120	94	214	7000
union, all arms (equal depth)	117	26	2	4	0	120/120	264	533	31601 (Å −4.5)
<i>baseline (per-entity)</i>									
entity_ewma	0	0	0	0	0	1	0	1 (measured at 100/day, not 1000)	--
<i>baseline (population)</i>									
eif	0	0	0	0	0	0	0	0 (measured at 100/day, not 1000)	--
hst	0	0	0	0	0	0	0	0 (measured at 100/day, not 1000)	--
iforest	0	0	0	0	0	0	0	0 (measured at 100/day, not 1000)	--
lof	0	0	0	0	12	0	0	12 (measured at 100/day, not 1000)	--
ocsvm	0	0	0	0	0	33	0	33 (measured at 100/day, not 1000)	--

METHOD	SPRAY	LATERAL	OFF-HRS	PRIV-ESC	LOW+SLOW	TAKEOVER	REAL	TOTAL	ALERTS
pca	0	0	0	0	0	0	0	0 (measured at 100/day, not 1000)	--

Planted: spray 320, lateral 40, off-hrs 64, priv-esc 24, low+slow 288, takeover 120, real 549.

Four readings, and the table is the argument rather than an illustration of it.

No single method is best at more than one thing. The population marginal takes every planted account takeover and nothing else at all. Detector V takes credential spray, lateral movement and privilege escalation and no takeovers the marginal does not already have. Detector I takes the real campaign. A reader looking for one row to deploy will not find one, and that is the finding: these detectors are answering different questions, and the questions are not redundant.

Detector V's own package documentation claimed it took credential spray, lateral movement and account takeover "from nothing to nearly everything". Measured, it takes them from nothing to between a third and two thirds. That is a real effect and a smaller one than was claimed, and the comment has been corrected to the numbers in this table.

The population marginal detects every planted account takeover: 120 of 120. A synthetic takeover moves an account onto population-rare values, which is exactly that detector's null, so the sweep is expected rather than surprising -- and it is the one place a population-scope model is the right instrument, in a paper that spends most of its length arguing the other way.

Low-and-slow is invisible to every arm of the framework: 0 of 288. It is the type the volume detector's dispersion widening was built to tolerate, so this is a confirmed prediction and not an unexplained gap. It is also the one type a baseline reaches and the framework does not -- local outlier factor finds 12 -- which is discussed in section 3.7.

Both p-value combinations are beaten by a component. The composite finds 116 of the marginal's 120 takeovers and loses the spray and lateral detections entirely; the corrected minimum keeps a third of the spray and a quarter of the takeovers. Neither reaches what the arms reach separately, and section 3.3 diagnoses why.

One method takes the maximum of every column at once, and it is the expensive one. The union at equal depth -- alert on anything any arm ranks highly -- matches the best arm on every attack type simultaneously and finds 264 events of the real campaign where no single arm exceeds 178. It spends 4.5 times the budget to do it, which is why the alerts column is in this table, and at equal cost the same rule is beaten by simply using the best arm. Section 3.4 is where that trade is priced.

This table is read at one budget and moves a great deal with it. At 100 alerts a day the marginal reaches 76 of the same 120 takeovers and the composite 24 of them, and **no method reaches any other planted type at all** - every remaining detection at that budget is an event of the real campaign. So "these detectors cannot express this attack" and "this budget cannot afford this attack" are different claims, and for four of the six types only the second one is true.

3.2 The per-entity detectors detect; the composite does not

Labelled LANL red-team events caught, days 7–14:

ARM	SCOPE	10/DAY	25/DAY	50/DAY	100/DAY
I novelty	entity	11	26	38	60
pairing	entity	4	8	8	59
IV marginal	population	0	0	0	0
II(a) timing	entity	0	0	0	0
II(b) volume	entity	0	0	0	0
composite (Fisher [4] + Brown [5])	mixed	0	0	0	0

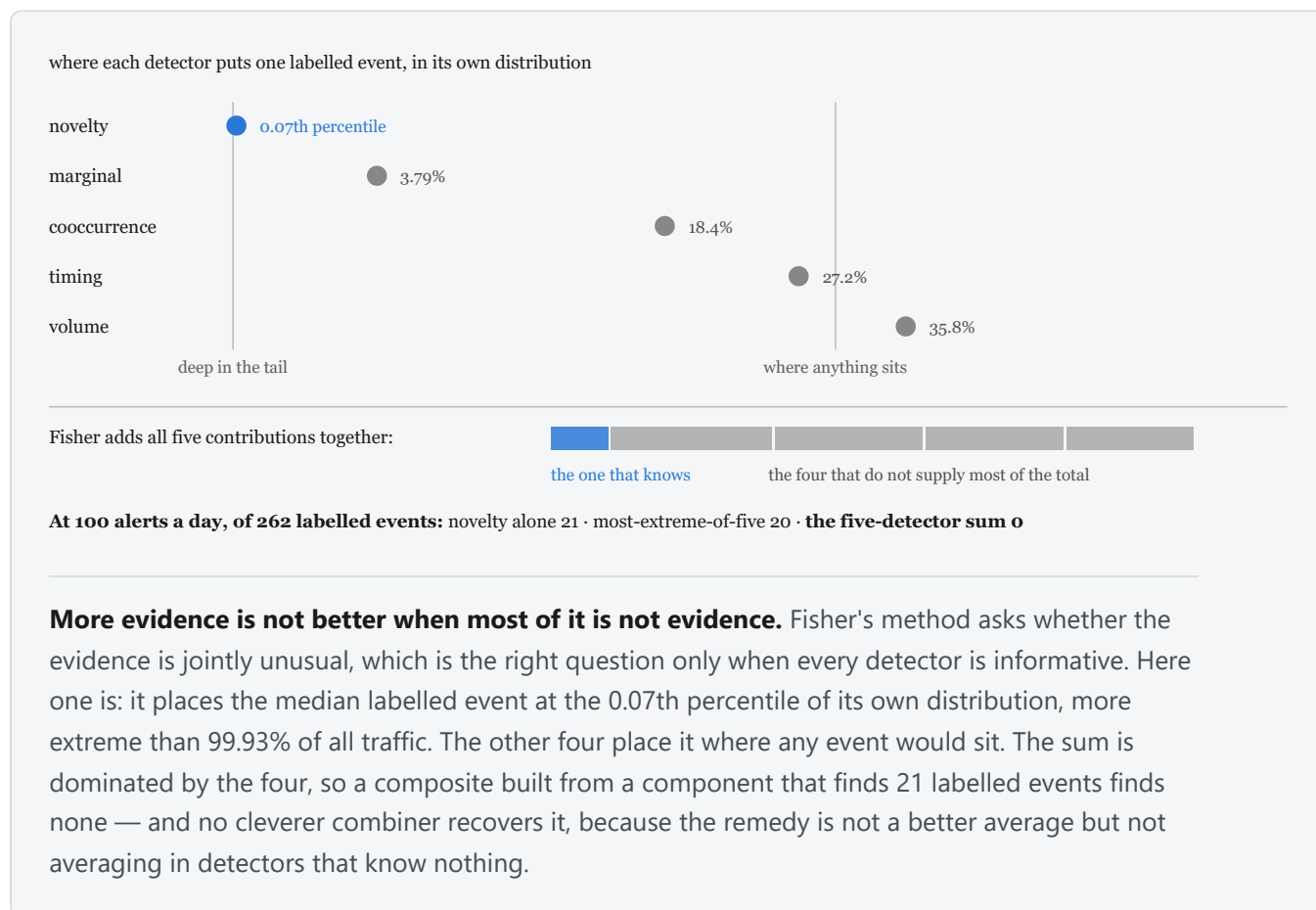
lanl-r11-d7-14-001 , 549 labelled events among 4,190,603 scored.

Replicated on a disjoint entity sample (lanl-holdout-r7-fixed-d7-9-001 , 262 labelled among 1,427,225 scored): novelty catches 2, 8, 15 and 21; cooccurrence catches 1, 2, 2, 2; the composite catches 0 at every budget.

At the tightest budget the novelty detector returns **11 true positives in 70 alerts — 16% precision against a base rate of 1.31×10^{-4} , a lift of about 1,200×**. Precision *improves* as the budget tightens, which is the signature of a ranking that is working.

The composite catches nothing at any budget on either corpus while its own best component catches 60. This is the paper's central negative finding and it is not a calibration detail.

3.3 The combination layer destroys the signal



Two combination rules are implemented. At 100 alerts/day:

CONFIGURATION	LANL-R11 (549)	LANL-HOLDOUT-R7-FIXED (262)
novelty alone	60	21
corrected minimum, Šidák [3]	47	20
Fisher [4] + Brown [5] (<i>the reported composite</i>)	0	0

No combination rule beats the best single detector. Combining *subtracts* value.

Both failures are diagnosed, and the diagnoses differ:

Fisher averages an informative detector with uninformative ones. Labelled events sit at the 0.07th percentile of the novelty detector's own distribution and at the 18th to 36th of every other detector's. Summing $-2 \ln P$ across five detectors dilutes one signal with four non-signals. Fisher is powerful against diffuse alternatives and the minimum against sparse ones, which is the distinction higher criticism [16] is built on; this signal is sparse.

The minimum compares raw p-values across detectors that share no scale. Under it the novelty detector carries **5,879 of the 7,000 retained alerts, 84%**, so the population marginal's signal never becomes the minimum however extreme it is *within its own distribution*. That signal is not weak; it is unreachable. The other five detectors divide the remaining 16% between them, and the marginal -- the arm that detects every planted account takeover on its own -- is left with 214 alerts, 3%.

This second diagnosis is the one §3.4 tests directly, by removing the shared scale altogether, and it survives only in part: the marginal's signal is recoverable and worth recovering, but Detector I holding most of the queue turns out to be closer to right than wrong.

The second diagnosis predicts its own fix. Conformal calibration [17] replaces each detector's model tail with its rank in that detector's own burn-in distribution, which is exactly what puts several detectors on one scale. At entity scope it already moves recall from 15 of 46 to 25 of 46.

The block structure Detector III conditions on is computed offline by Leiden [10] and never in the scoring path, because community detection is stochastic and the scoring path may not be (R4).

A related incompatibility was found while measuring the sixth detector: with six detectors the burn-in covariance implies $\text{Var}[X^2] = -27.5$, which no joint distribution of the statistics can produce. The estimator is measuring the marginals' misspecification rather than the detectors' dependence.

3.4 Alerting when any detector fires

Both combinations in §3.3 ask the detectors to agree. A third rule does not: alert on any event that *any* detector ranks highly. It is the minimum's question with the scale removed -- each arm ranks the day on its own p-value, an event scores the best rank it reaches in any arm, and only the within-arm order is read. Alerts are deduplicated, since the arms' sets are not disjoint. Ties break on the event identity and never on a p-value: rank collisions are structural, every arm has a rank 1, and breaking them on log p would hand each one back to the arm whose p-values are numerically smallest.

It is charged two ways -- **at equal cost**, truncated to the same alerts a day every other arm gets, and **at equal depth**, every arm keeping its own top B with the union emitted whole. At 1000 alerts a day:

METHOD	LANL-R11 TP	ALERTS	LANL-INJ TP	ALERTS
best single arm	201	7,000	384	7,000
union, per-entity arms, equal cost	106	7,000	118	7,000
union, all arms, equal cost	96	7,000	214	7,000
union, per-entity arms, equal depth	278	25,930	477	25,917
union, all arms, equal depth	278	32,134	533	31,601

At equal cost the union is strictly dominated on both corpora at every budget -- fewer labelled events *and* more false alarms than just using the best arm: 96 against 201, 214 against 384. No exchange rate rescues a dominated option.

Why is visible in the two corpora disagreeing about the population marginal. On the injected corpus, including it moves the union from 118 to 214, since its 120 account takeovers are detections the per-entity arms do not have. On the real campaign, including it moves the union from 106 *down* to 96: there it detects nothing and still consumes a sixth of the budget. Rank fusion gives every arm an equal share, and `volume`, which detects nothing anywhere, draws the same share as Detector I.

This refutes part of §3.3's diagnosis. That section reads the minimum's failure as the marginal's signal being unreachable behind a mismatched scale. Rank fusion makes it reachable and the result gets worse, so crowding-out was not the binding defect: Detector I holding 84% of the queue was mostly *correct*, because it is the better arm. What survives is that reaching the marginal recovers real detections, which the +96 shows. What fails is the implied remedy -- an equal allocation across arms of very unequal quality is worse than letting the best arm take everything.

At equal depth the union finds what no single arm finds. It takes the maximum of every column of §3.1's table at once, including all 120 takeovers and 264 real-campaign events where no arm exceeds 178. That is complementarity made concrete, and it costs 4.5 times the budget. Whether to buy it is what §2.6's objective decides. Against the best single arm, the union at equal depth is preferred only above these exchange rates:

	100 ALERTS/DAY	1000 ALERTS/DAY
lanl-r11 , all arms	$v/c > 190$	$v/c > 325$
lanl-inj , all arms	$v/c > 35$	$v/c > 164$

Needing a catch to be worth 164 wasted investigations is a hard sell. Needing 35 is not, and at 100 a day on the injected corpus the union nearly doubles detections -- 151 against 76 -- for 4.9 times the alerts. That is the one configuration where the rule is worth deploying.

The rule also gives up what the rest of the framework is built on: a fused rank is not a p-value and no null distributes it, so this arm reports a selection rather than a calibrated tail probability, admissible only because R6 no longer ties volume to a stated error rate. Each alert still carries the p-value of the detector that raised it. What the experiment points at is an allocation that is neither a shared threshold nor an equal quota, but a share per arm proportional to what that arm has earned -- a calibrated per-alert probability, the same missing piece §3.6 reaches from the other direction.

3.5 Widening the budget, and the sixth detector

lanl-r11-b1000-union-d7-14-002 is the first recorded run to include Detector V, and the first at a budget of 1000 alerts a day. 549 labelled events among 4,190,603 scored:

ARM	10/DAY	100/DAY	1000/DAY
I novelty	11	60	201
V noveltyrate	0	22	185
pairing	4	59	127
corrected minimum	4	47	161
composite	0	6	113
II(a) timing	0	0	6
II(b) volume , IV marginal	0	0	0

Three findings.

Detector V detects. It reaches 185 of 549 at the widest budget, second only to Detector I, and on the injected corpus it is the broadest arm in the paper (§3.1). It exists because Detector I's p-value for a first-ever value is roughly one over the size of the account's history, which leaves it structurally unable to alert on a small account however anomalous; the rate question is scale-free instead. Two corpora now agree that it works, which was the condition this paper set for flipping it on by default -- so that default is now a decision waiting to be taken rather than evidence waiting to arrive.

Conformal calibration moves the composite off zero, and not far enough. It catches 6 at 100 alerts a day where the uncalibrated composite caught 0 -- the predicted direction, since putting the detectors on one scale is what lets an informative one reach the minimum -- and that is still an order of magnitude below its own best component's 60. Per-arm figures are unchanged by calibration, as they must be: a rank transform inside one detector is monotone and cannot reorder that detector's own alerts.

Widening the budget buys recall at a steep price in precision. Detector I's recall rises from 2.0% to 36.6% between 10 and 1000 alerts a day while its precision falls from 15.7% to 2.9%. A budget of 1000 a day is 7,000 alerts against 549 labelled events, so most of what it permits cannot be anything but cost.

3.6 A budget is a ceiling, not a quota

Truncating each queue where U peaks, at an exchange rate of ten false positives to one true positive ($v/c = 10$), on the corrected-minimum arm:

BUDGET	PERMITTED	TP	OPTIMAL	TP	PRECISION	SUPPRESSED	TP FORGONE
10/day	70	4	30	4	6.7% → 13.3%	40	0
100/day	700	47	221	47	6.7% → 21.3%	479	0
1000/day	7,000	161	315	74	2.3% → 23.5%	6,685	87

At 10 and 100 a day the truncation is free: two thirds of the queue goes for no loss of detection at all. At 1000 it becomes a decision -- the objective discards 6,685 alerts and 87 true positives with them, because at this rate those 87 are not worth 6,685 wasted investigations -- and precision rises tenfold.

For the composite the optimum is to emit **nothing at any budget**, including the one where it finds 113 true positives, which do not pay for 6,887 false ones at $v/c = 10$. The objective declining to deploy a detector is a usable answer, and the framework's own headline arm is what receives it.

This is an oracle bound: the optimum is located using the labels, so it measures the headroom a cutoff has rather than being a shippable rule. A deployable version needs the same calibrated per-alert probability \$3.4 arrives at.

3.7 What the baselines do

Six population-scope baselines spanning four inductive biases — isolation forest [11], extended isolation forest [12], half-space trees [13], local outlier factor [14], one-class SVM [15] and PCA reconstruction error — all run from their reference scikit-learn implementations [18] rather than being reimplemented, so a difference in the comparison is a difference in method. They were measured on two corpora and the two answers differ.

On the matched comparison (`baselines-holdout-r7-d7-9`, the same 262 labelled events §3.2 replicates on) all six detect **0 at every budget**. One per-entity baseline, an uncalibrated EWMA z-score, detects 1. Isolation, density, boundary and linear-subspace models fail together, and the category census says why: not one labelled event of the real campaign is a population-marginal outlier.

On the injected corpus they are not all zero, and the exception is the interesting one. Against 1,405 labelled events at their widest measured budget, one-class SVM detects **33 of 120 account takeovers** and local outlier factor detects **12 of 288 low-and-slow events** — the one attack type no arm of this framework reaches at any budget. A synthetic slow exfiltration is a small, sustained departure that the volume detector's dispersion widening is built to tolerate; a population density estimate has no such tolerance and picks some of it up. That is a real capability this framework does not have, and the honest reading is that the two scopes are complementary rather than that one dominates.

Both baseline figures come from an easier problem than the framework's, in two ways that both favour the baselines. They read a 1-in-100 sampled feature table on which the labelled share is **3.0% against the framework's 0.031%, a base rate 97 times easier**, and their budget permitted them **1.3% of their corpus against the framework's 0.16%, an 8.3 times larger share**. Given both advantages they reached 33 and 12.

So the direction of the comparison — per-entity beats population on this campaign — is what the evidence supports, and it is narrower than a table of zeros would suggest. The margin over the per-entity baseline rests on a single event and could reverse on another campaign.

4. Threats to validity

Stated because a result that does not name its own weaknesses is not a result.

1. **One corpus, one campaign.** Every quantitative claim rests on LANL authentication and a single red-team campaign whose characteristics are not known to be representative.
 2. **Entity sampling inflates measured rates.** Labelled entities are exempt from every sample, so a subset carries a fraction of the background against all of the labelled population. Sampled rates are **not** comparable to full-population ones.
 3. **The per-arm detectors have never been measured on the full corpus.** The only full-population run records the composite alone, at 0. Whether the novelty detector's 60 survives at a base rate ten times lower is **unmeasured**, and it is the most important outstanding experiment.
 4. **The per-entity baseline margin is thin**, resting on one event.
 5. **Entity-day results are confounded by activity**, and the confound accounts for most of the effect: pricing in the event count takes 25 of 46 down to 2.
 6. **The open-vocabulary estimator is untested on an open vocabulary.**
 7. **No committed result was produced through the persistent store.** Every recorded run used in-memory state; the database path exists and is exercised only by tests.
-

5. Conclusion

The evidence points in one direction, and it is not the direction the design anticipated.

Per-entity conditioning is what reaches the real campaign; scope is not a ranking. On the real intrusion the per-entity novelty detector finds labelled activity at every budget tested, replicated across disjoint entity samples, while six published population-scope models and the framework's own population arms find none. The mechanism is visible in the category census: those events are not population outliers, so no technique applied at population scope reaches them.

That is a claim about one campaign and not about scope in general, and the planted attacks say why the distinction matters. The population marginal detects **every one of 120 account takeovers** and a population density baseline reaches the low-and-slow exfiltration no arm of this framework touches. An earlier version of this paper concluded that population-scope conditioning does not work; measured against ground truth it owns two attack types outright. The scopes are complementary, and the useful statement is which question each answers rather than which is better.

No combination tried beats its own best component at equal cost. Three rules now: Fisher with Brown's correction, the corrected minimum, and a union that alerts when any arm ranks an event highly. The third was built to test the second's diagnosis -- that an informative arm was unreachable behind a mismatched p-value scale -- and it refutes it. Removing the scale makes the union *worse*, because an equal share of the budget for every arm hands the same share to an arm that detects nothing as to the arm carrying the signal.

The defect is therefore not the combining but the allocation. What none of the three does is divide a budget across arms in proportion to what each has demonstrably earned, and doing that needs a calibrated per-alert probability -- the same prerequisite the cutoff work arrives at. Until then, presenting each signal on its own terms is also the more actionable choice: "this account used a program it has never used" is an instruction, and a blended score is not.

Move the unit of analysis to where the design already put it. The framework argues that the entity is the unit; the evaluation ranked events. Closing that gap produced the only non-zero composite detection, and the remaining work is to remove the activity confound rather than to discover the effect.

Make precision the control. Alert volume is now explicitly unbounded and the objective is expected utility, so an unbounded queue that is mostly right is preferred to a bounded queue that is mostly wrong. Measured on a real run, the utility-optimal cutoff discards two thirds of a queue at no cost in detections — the headroom for a deployable cutoff rule is large, and building one needs a calibrated per-alert probability.

What is not claimed: that this detects insider threat at deployable precision. Sixteen per cent of a queue being real is a thousand-fold improvement on chance and still not good enough to alert on unattended, and low-and-slow exfiltration — 288 planted events — is invisible to every arm of this framework at every budget while a population density baseline reaches 12 of them, which is a capability the per-entity formulation simply does not have. What is established is narrower and more useful — that per-entity conditioning carries the real campaign where population conditioning carries none of it, that population conditioning owns attack types per-entity conditioning cannot see, and that what stands between them is not the combining rule but how a fixed budget is divided among arms of very unequal quality.

References

1. Axelsson, S. *The base-rate fallacy and its implications for the difficulty of intrusion detection*. ACM Conference on Computer and Communications Security, 1999.
2. Kent, A. D. *Comprehensive, Multi-Source Cyber-Security Events Data Set*. Los Alamos National Laboratory, 2015. CCo 1.0.
3. Šidák, Z. *Rectangular confidence regions for the means of multivariate normal distributions*. Journal of the American Statistical Association 62(318), 1967.
4. Fisher, R. A. *Statistical Methods for Research Workers*. Oliver and Boyd, 1932.
5. Brown, M. B. *A method for combining non-independent, one-sided tests of significance*. Biometrics 31(4), 1975.
6. Benjamini, Y. and Hochberg, Y. *Controlling the false discovery rate: a practical and powerful approach to multiple testing*. Journal of the Royal Statistical Society B 57(1), 1995.
7. Benjamini, Y. and Yekutieli, D. *The control of the false discovery rate in multiple testing under dependency*. Annals of Statistics 29(4), 2001.
8. Good, I. J. *The population frequencies of species and the estimation of population parameters*. Biometrika 40(3–4), 1953.
9. Karrer, B. and Newman, M. E. J. *Stochastic blockmodels and community structure in networks*. Physical Review E 83, 2011.
10. Traag, V. A., Waltman, L. and van Eck, N. J. *From Louvain to Leiden: guaranteeing well-connected communities*. Scientific Reports 9, 2019.
11. Liu, F. T., Ting, K. M. and Zhou, Z.-H. *Isolation Forest*. IEEE International Conference on Data Mining, 2008.
12. Hariri, S., Carrasco Kind, M. and Brunner, R. J. *Extended Isolation Forest*. IEEE Transactions on Knowledge and Data Engineering 33(4), 2021.
13. Tan, S. C., Ting, K. M. and Liu, T. F. *Fast anomaly detection for streaming data*. International Joint Conference on Artificial Intelligence, 2011.
14. Breunig, M. M., Kriegel, H.-P., Ng, R. T. and Sander, J. *LOF: identifying density-based local outliers*. ACM SIGMOD, 2000.
15. Schölkopf, B., Platt, J. C., Shawe-Taylor, J., Smola, A. J. and Williamson, R. C. *Estimating the support of a high-dimensional distribution*. Neural Computation 13(7), 2001.
16. Donoho, D. and Jin, J. *Higher criticism for detecting sparse heterogeneous mixtures*. Annals of Statistics 32(3), 2004.
17. Vovk, V., Gammerman, A. and Shafer, G. *Algorithmic Learning in a Random World*. Springer, 2005.

18. Pedregosa, F. et al. *Scikit-learn: machine learning in Python*. Journal of Machine Learning Research 12, 2011.

Generated by `cmd/thesis` from `docs/PAPER.md`, which stays canonical for the prose: this page is never edited directly, so the two cannot disagree. Every quantitative claim traces to a recorded run in `results/`. Diagrams are hand-authored inline SVG with no external resources, and their two carrying colours are validated for contrast and colour-vision separation against both the light and dark surfaces.